Cyber Verification Program - appeal evidence

Applicant: Michal Budek (GitHub `mbuasm`) **Date:** 2026-10-29 **Purpose:** supporting material for an appeal against the CVP decision ("submitted evidence of eligibility doesn't meet our requirements"). This document is built **only from the commit history** of four private repositories I own and develop. No source code or secrets are included here; every claim points to a commit SHA that Anthropic can verify on request (read access to the repositories can be granted to a reviewer account).

> Uwaga dla autora (PL): wersja robocza do weryfikacji przed scaleniem. Wszystkie SHA i daty pochodza z GitHub API (29.10.2026). Sprawdz sekcje "What I am asking for" i dopisz, co chcesz uzyskac z CVP.

---

1. Context

Repository	Created	Language	Commits (main)	What it is
`mbuasm/Maszyny-alert`	2026-09-10	C# / .NET, PowerShell	961	Windows desktop monitor for CNC machines (Aidite 520/580, Premile, Cameo). Reads machine HMI screens over the RFB/VNC protocol with its own RFB client, runs OCR, raises alarms, syncs state between operator PCs (multi-computer "cluster"), installs via Inno Setup with an elevated update task.
`mbuasm/VNC-Alert`	2026-10-14	C# / .NET, PowerShell	19	Continuation of the same product under its release name, with the shared CI (secret scanning, SAST, dependency audit, UI tests) and release gates.
`mbuasm/serwer-laptop`	2026-09-09	Bash, Python, PowerShell	1182	Infrastructure of the self-hosted server: GitHub Actions runners, reusable CI workflows used by the two repos above, secret/PII scanner, Trivy image scanning, nftables isolation, SOPS/age secrets. Referenced in section 2.6a.
`mbuasm/qc`	2026-10-26	Python	64	Quality-control workstation for a dental prosthetics lab: 3D scan of zirconia restorations, chip detection against design STL files, identification of pieces to patient orders, LED frame, Excel tick-off. Processes patient data; see section 2.9.

Both projects run on a factory floor: they handle VNC credentials for production machines, an admin password protecting downtime reports, an HMAC "network key" for the computer group, an update channel token, and an elevated (UAC) helper. That is why most of the security work below exists.

The work is **defensive**: secure code review, threat-driven fixes, hardening of a self-written network protocol client, secret handling, CI security gates. This matches the activities the CVP rejection letter itself lists as in-scope for the program's audience.

---

2. Security work by area (with commits)

All SHAs are from `mbuasm/Maszyny-alert` unless marked `VNC-Alert`. Dates are commit author dates.

2.1 Structured security reviews and fix cycles

Two formal internal security reviews with numbered findings, each followed by red tests and fixes.

Date	SHA	Summary
2026-10-04	`4a1f026`	**Red tests for security review R-01..R-13** (review "RECENZJA-P7b-04.10" of the elevated update task): task registered only when data is ready; `updates-admin` task directory must be non-writable by Users; task verifies owner, reparse point and DACL of its directory and parent before any work (unprotected -> exit code 7, no read/write); fresh `run-<guid>` copy per run; task bound to the program version it was registered with; HTTPS-only update URL (no localhost exception); `Global\` kernel objects only for objects created by the program; refuse update without checksum and size.
2026-10-04	`9cc4ef6`	**Fixes for R-01..R-05, R-07..R-13** across the Inno Setup script, `Initialize-Data.ps1`, `Register-UpdateTask.ps1`, `Update-Task.ps1`, `UpdateTask.cs`, `WindowsUpdateInstaller.cs`, `StopRequest.cs`. Closes a real privilege-escalation path: an elevated scheduled task that previously could be pointed at a user-writable directory.
2026-10-04	`b8db46e`	**P6 security package** (findings A2-B03, A1-B06, A1-O-19, A3-O19): reject weak RSA exponent (0, 1, even) from the VNC server before sending the password; log key fingerprint; optional key pinning `machines[].rsaAesKeySha256`; test suite no longer contains a plaintext recovery password; `history.csv` neutralises spreadsheet formula injection (`= + - @`); `updates.url` with embedded credentials rejected. Adds `SecurityHardeningTests.cs`.
2026-10-05	`f7c1fe9`	**Secret exposure in UI fixed**: the first-run / tray / `--setup` settings window loaded the saved network key into a plain text field with a "Copy" button. Now the window is built with `includeSecrets:false`: network key and update token groups are removed from the view tree, never loaded into the view model, and saving cannot clear or overwrite stored secrets.
2026-10-05	`3b4aa1b`	Tests for the above (`SetupViewSecretsTests.cs`, `InitialSetupGroupKeyTests.cs`).
2026-10-04	`9d76665`	Post-cycle documentation: uninstall leaves `secrets.dat` and `%LOCALAPPDATA%` data (documented explicitly as finding A3-R07), `killapp` stop window bounded to 10 min (A3-O15).
2026-10-05	docs	`handoff-P7-druga-recenzja-2026-10-04.md`, `handoff-P7-trzecia-recenzja-2026-10-04.md`, `handoff-naprawy-U02-po-recenzji-2026-10-05.md` - second and third review rounds of the same component.

2.2 Own RFB/VNC protocol client - authentication and crypto hardening

The product does not use a third-party VNC library. `MaszynyAlert.Core/Rfb` is a hand-written RFB client (RFC 6143 plus RealVNC RSA-AES security types 5/6/129/130).

Date	SHA	Summary
2026-09-10	`ae45f6f`	`FakeRfbServer` test double covering RFB 3.3/3.7/3.8, `None`/`VncAuth`, Raw/Hextile/CopyRect, plus 69 RFB client tests - the harness later used for security tests.
2026-09-18	`c7ba8dc`, `560176b`, `73b54d6`	`RfbSecurityType.cs` / `RsaAesHandshake.cs`: implementation of RealVNC RSA-AES handshake (RA2, RA2ne, RA2_256, RA2ne_256) for the Aidite 580 machine; unknown security types (13, 133, 192 offered by the real device) deliberately not guessed, logged numerically; RFB 005.000 greeting accepted; username negotiation asked from the server instead of refusing.
2026-10-04	`b8db46e`	Weak-exponent rejection, key fingerprint logging, optional SHA-256 key pinning, `FakeRsaAesServer.cs` + `RsaAesHandshakeTests.cs` (negative cases).
2026-10-11	`5f942f8`	`SetPixelFormat` taken from `ServerInit` for Qt Embedded servers and retry "fuses" (bounded reconnection) - robustness against malformed/odd server behaviour.

2.3 Multi-computer cluster protocol - replay protection and integrity

State between operator PCs is exchanged over UDP with HMAC ("network key").

Date	SHA	Summary
2026-09-13	`f66c1fb`	**Harden cluster replay protection and resume handling** (`ClusterNode.cs`, `PeerTable.cs`, `ConfigLoader.cs`).

Date	SHA	Summary
2026-09-14	`455cfe9`	Cluster runtime v2: UUID/ACK takeover, STATE v2 packet bounds and truncation of oversized STATE, **UAC helper transaction and secrets lock**.
2026-10-11	`a2ca966`	A2-05: handling of reordered observation chunks **with replay protection** (`A2ObservationReplayTests.cs`).
2026-09-12	`19ec865`	Package 3: secure ACK episodes, alarming made independent of OCR (`AckMemory.cs`, `AlertStateMachine.cs`).

2.4 Privilege boundary: UAC helper and named pipe ACLs

Date	SHA	Summary
2026-09-15	`95ced4c`	Named pipe between the unprivileged app and the UAC-elevated helper: `PipeOptions.CurrentUserOnly` does not match an elevated token (owner = Administrators group). Replaced with an explicit ACL granting access **only to the current user's SID** (which the elevated token still carries). Documented in `raport-diagnoza-zapory-grupy-2026-09-15.md`.
2026-09-14	`455cfe9`	Helper transaction with rollback (`GroupApplySession`, `AppOrchestrator`) so a half-applied elevated change cannot be left behind.
2026-09-13	`1081147`	**Harden Windows installer data initialization** (`MaszynyAlert.iss`, +3209 lines) - data directory layout and permissions set by the installer.
2026-10-04	`9cc4ef6`	See 2.1: elevated task validates owner/DACL before running.

2.5 Secret handling (DPAPI, no secrets in args/logs/dumps)

Date	SHA	Summary
2026-09-10	`d8bb8f7`	DPAPI-backed secret storage introduced in `MaszynyAlert.Windows`.
2026-09-13	`419e077`	Password-protected downtime reports (admin password), `Check-PrivateMaterials.ps1` guard script.
2026-10-09	`548ed6b`	Diagnostics collector password store: `probe.exe haslo zapisz/usun/lista`, DPAPI CurrentUser, password read from hidden prompt or pipe, **never from a command-line argument**; password never written to the scheduled task, logs or summary. `DpapiFactAttribute` skips (not fake-passes) tests where DPAPI is unavailable.
2026-10-11	`8398687`	Password passed via process environment instead of a PowerShell 5.1 pipe (encoding/BOM corrupted non-ASCII passwords); `DiagnozaSafetyTests.cs`.
2026-10-12	`34aa3e2`	Password env var reliably removed after use in both Windows PowerShell 5.1 and pwsh 7 (`[NullString]::Value` vs `$null` behaviour measured and documented).
2026-10-12	`1e38fdd`	**R-07: diagnostics dump of RealVNC Viewer settings leaked `RSA_Private_Key`** (REG_BINARY) into the ZIP because `-ExcludeProperty *Password*` did not cover it. Now every value is rewritten explicitly: any name matching key/password/passwd/secret/token/credential -> `<omitted>`, binary data only as size; address-book lines with those words removed. Regression test `kolektor-probe-02`.
2026-10-12	`46ffdaf`	Integration of collector tests: stop handling and RealVNC secrets (PR #162).
2026-10-09	`7682393`, `41f84f2`, `60a3537`	Installer tests compute data hashes **after** the operator probe, so integrity checks of installed data are real (root cause of a red CI found and fixed).

2.6 Supply chain, release integrity and CI security gates

Date	SHA	Summary
2026-09-18	`d4f7208`	**Authenticode signing pipeline** in CI (`Sign-Files.ps1`, Inno SignTool, `CODESIGN_*` secrets) and signing instructions (`docs/podpis-instalatora.md`).
2026-10-03	`5b504d9`	Updates: checksum taken from the release catalogue; helper no longer depends on `Get-FileHash`; buttons do not hang on UAC.
2026-10-04	`9cc4ef6`	Update task refuses packages without checksum and size; HTTPS-only.
2026-10-18	`VNC-Alert d902460`	CI gates: release workflow tests, **gitleaks and SAST exceptions only via files protected by CODEOWNERS** (`.gitleaksignore`, `.sast-wyjatki`); `ReleaseWorkflowGateTests.cs`.
2026-10-18	`VNC-Alert 79e6dbe`	UI test runner collects system diagnostics on failure (Defender, Code Integrity, AppLocker, event log, processes).
2026-10-25	`VNC-Alert b7292e5`	CI and release rules; **git hook refuses a release from `main`** (release only from a reviewed branch/PR).
2026-10-26	`VNC-Alert c0d2a1c`	Release check does not rely on the `ready_for_review` trigger (gap found where draft->ready lost the check).

The shared reusable workflow (`mbuasm/serwer-laptop/.github/workflows/testy.yml`, used by both `VNC-Alert` and `Maszyny-alert` `ci.yml`) enforces, on every PR:

- **gitleaks** 8.30.1 downloaded with a pinned SHA-256 (mismatch = fail without running), default rules only (a `.gitleaks.toml` in the repo is deliberately ignored so a PR cannot weaken the rules), `--redact`, `--ignore-gitleaks-allow`, scanning both the commit range and the checked-out tree;
- **Semgrep OSS** 1.179.0 (pinned), `p/default` rules, `--metrics=off`, `--disable-nosem` (an inline `nosemgrep` in a PR cannot silence a rule); exceptions only from `.sast-wyjatki` under CODEOWNERS;
- **dependency audit** job;
- all GitHub Actions pinned to commit SHAs;
- deployment only after `skan-sekretow`, `sast`, `zaleznosci` and both test matrices are green.

2.6a Scanner setup: own secret scanner, gitleaks/Semgrep gates, Trivy image scanning

Third repository: `mbuasm/serwer-laptop` (created 2026-09-09, 1182 commits on `main`) - the infrastructure repo of the self-hosted server (WSL on a Windows host "MSI") that runs the GitHub Actions runners, the reusable CI workflows used by both product repos, and the production containers. The scanner work there, in order:

Date	SHA	Summary
2026-09-22	`5ae5c32`	**Own secret scanner** `narzedzia/skan-sekretow.py` (Python 3.12, standard library only, no network): detects PEM/age private keys and GitHub, Google API, AWS, Slack, Stripe tokens; output contains rule name, file, line and revision, **never the value**; exit codes 0 = clean in the scanned range, 1 = hits, 2 = incomplete scan (shallow history, missing artifact, file > 32 MiB) - an incomplete scan is never reported as clean. Pre-commit hook scans **index blobs**, so editing the working file after `git add` cannot hide a token. Documented limits in `docs/bezpieczenstwo/skan-sekretow.md` ("basic control of known formats, not a full secret scanner").
2026-09-26	`dc6aeb0`	**T15: secret scan as a required CI check** (`testy / skan-sekretow`): `--range BASE..HEAD` mode (blobs added/changed in every commit of the range, including merges; shallow clone / bad revision / submodule -> exit 2); job runs the **trusted scanner installed on the host** (`/usr/local/bin/skan-sekretow`, root:root 0755), not the copy from the PR checkout, so a PR cannot modify the scanner that judges it; deploy job requires it; GitHub ruleset `ruleset-testy.json` makes the check mandatory.

Date	SHA	Summary
2026-09-30	`dc5853b`, `63ddbd5`	Scanner extended to **release artifacts**: `--rozpakuj` unpacks ZIP, installer size check; `innoextract` 1.9/1.10 cannot read Inno Setup 6.7.3 installers, so those are reported as *incomplete scan* instead of a false "clean". Runner alerts: queued jobs without a runner, runner group silently switching to `visibility: all`, PAT expiry warning 14 days ahead.
2026-09-30	`f8fa218`	Deployment of the scanner on the host with installed-file hashes recorded (`skan-sekretow cfe2934a`), backup copy before install, verification run on a throwaway repo (`proba-runner`).
2026-10-02	`277f434`	Scanner recognises 7z/MSI/CAB/RAR by signature (incomplete scan unless unpacked; `--scisle` turns it into exit 2); **outbound secret filter** for the Discord notification bot (`bot/filtr-sekretow.txt`: `tskey-`, `Bearer`/`Basic` headers, etc.) so alerts cannot leak credentials; in the same commit: nftables rules isolating containers (only Traefik may reach apps, non-privileged accounts cannot reach container ports), HAProxy whitelist for the Docker socket proxy (only `GET /containers/json`, `/containers/<id>/json`, `/stats`).
2026-09-29	`5dba241`	Watchdog alerts routed through the common secret filter (`powiadom --filtruj`) with a fallback filter; the bypass flag `przefiltrowana=1` removed - **every alert body goes through the filter**.
2026-10-17	`8a0a91e`	**PII detection**: Polish national ID (PESEL) with checksum validation added to the scanner as a warning class; agent sandbox (`bwrap`, tmpfs + read-only mounts) for automated sessions.
2026-10-20	`778ccf2`	File-sync tool refuses artifacts only when the PESEL warning count is > 0 (the scanner summary line itself was being matched as a hit - false positive fixed with tests, real PESEL still rejected with code 77).
2026-10-17	`393ae05`	gitleaks tuning: `image:` lines of container tags were flagged as `generic-api-key`; allowlist scoped to that regex target only, verified that a real `ghp_` token is still caught (exit 3).
2026-10-17	`3282979`	E17.19-E17.22: CI can fall back to GitHub-hosted runners, but **host-only steps (trusted scanner, machine Python, release mailbox, deploy) are skipped there and the run is marked as degraded** rather than pretending the scan happened; emergency-merge and power-loss runbooks; separate accounts per role.
2026-10-18	`d42d983`	Shallow-clone bug: the runner workspace shared between jobs kept stale entries in `.git/shallow` (PR merge refs GitHub no longer has), `git fetch --unshallow` did not clear them, scanner correctly refused `--range` with exit 2. Fix: the secret-scan job always starts from a **fresh clone**. Root cause reproduced on git 2.55 and 2.43 and documented.
2026-09-30	`354eae0`, `c3d98ed`, `89f3328`	**Weekly CVE scan of production container images** (`bin/skan-obrazow` + systemd timer, Trivy 0.74.0 pinned by SHA-256 in `wersje.sha256`); alerts only for CRITICAL, or HIGH with a fix available; runs as the `deploy` account with a hardened unit (`ProtectHome`, caches moved); first real run found 10 images with fixable CRITICAL/HIGH, platform images were refreshed the same day (`89f3328`: nginx HIGH 1->0, MySQL fixable HIGH 37->27). Accepted residual findings recorded in `odbior-2026-09-28-G3.md`.
2026-09-24	`92db8e4`	Application image rebuilt without `pip`/`setuptools` after Trivy findings (CRITICAL 0, fixable HIGH 0).
2026-09-22	`bef0049`, `54cd197`	Base image tags pinned (PostgreSQL 17.11, MySQL 8.4.11, Valkey 8.1.10); fixes after an audit of the privileged wrappers (`cf`, `sekret`, `wdroz`, sudoers).
2026-09-18/19	`2d1b7d5`, `d1349e5`, `ddb432f`, `d86507e`	Secrets at rest: age keys + SOPS, `*.sops.env` ciphertexts only in git, `sekret` wrapper with "secret before sudo" policy, denial log for deploy/agent layers, age key checksum.

The `testy.yml` workflow (history: `c46dc07`, `004b4ec`, `dc6aeb0`, `295555f`, `0709903`, `63ddbd5`, `07bf625`, `382623e`, `393ae05`, `3282979`, `d42d983`, `9390ab3`) is where the gitleaks and Semgrep gates described in 2.6 live; the design rules there (pinned scanner versions with SHA-256 check, repo-local scanner configs ignored, `--disable-nosem`, exceptions only via CODEOWNERS-protected files) were introduced in the E17.11 work of 2026-10-17 (`382623e`: "CI gates, UI tests, security review, release, manifest").

2.7 Resource exhaustion and robustness

Date	SHA	Summary
2026-09-15	`3d06af9`	Hard disk-space cap for screen captures (`paths.capturesMaxMegabytes`, validated 20-5000, default 200) after a flickering HMI produced thousands of files per day and filled the workstation disk.
2026-09-25	`a8a4742`	"Tool life" suppression: **three safety gaps** closed - hung OCR engine left alarms muted; a changed error during slow OCR was not seen as a change; a "no alarm" rule could win by file order over a real error.
2026-10-12	`f81496c`, `2a03a0a`, `8d47585`	Qt "fuse" (circuit breaker) state survives monitor rebuilds; single retry time and single warning per step; polling and test-screen file cannot cause a false takeover.
2026-10-06	`8b6b588`	ACL-dependent test made conditional on the account's rights (runner cannot change ACL of its workspace) instead of silently passing.
2026-10-12	`e09d8c1`, `5b80bda`, `800a47c`	Tests: start and operation with a held shared-config lock, corrupted file, ACL; test that removes write permission restores ACL inheritance (no leftovers in `%TEMP%`).

2.8 Audits with reproductions (evidence-driven)

Date	SHA	Summary
2026-09-12	`ea8e799`	Stability audit and fix plan with bug reproductions.
2026-09-30	`cf9687e`	CI audit 30.09 (state, cheat-sheet, handoff, PR #88).
2026-10-10	`60421fa` .. `72c4c23`	Downtime/report audit A1/A2/B/C/D: reproductions committed as tests first (`ad7ffaa`, `defdad9`, `8d73e7e`, `ad0efa9`), then fixes queued by priority P0/P1.
2026-10-11	`81a401c`, `11ae8e5`, `eb68c84`	Audit closed: 16 fixes merged (PRs #136-#151), 17 reproduction tests enabled, green CI recorded.

2.9 Dental prosthetics QC station (`qc`) - patient data handling by design

Fourth repository: `mbuasm/qc` (created 2026-10-26, 64 commits on `main`, Python 3.12). A workstation program for a zirconia milling room in a dental prosthetics laboratory where I work: in the evening it scans a plate of green-state crowns and bridges with a laboratory 3D scanner, registers each piece to its design STL (Open3D FPFH + RANSAC, ICP) and marks edge chipping before sintering; in the morning it identifies each sintered piece and assigns it to the patient order (tray), drives an LED frame to light the slots, and ticks finished orders in the company Excel. The STL designs live in OneDrive/SharePoint order folders whose names contain **patient surnames**, so the project processes personal and health data from day one. The commit history shows the controls were designed in before any production data was touched:

Date	SHA	Summary
2026-10-26	`53f38cd`	Project skeleton with the data rules in `CLAUDE.md` and `.gitignore` from the first commit: **no real STL, scans, order folder names, Excel rows or milling reports in the repo** (GDPR); tests only on synthetic or anonymised data; **the program sends nothing to the internet**; LED frames receive only slot and tray numbers, never names. `.gitignore` blocks `*.stl`, `*.ply`, `*.obj`, `*.pdf`, `*.db`, `*.sqlite*`, `*.log`, `excel-log*.csv`, local settings and the data folders, with explicit allow-lists only for `tests/dane/` and `modele/`.
2026-10-26	`97d8d09`	`.gitignore` tightened: data directories anchored to the repo root so the rule cannot be bypassed by a nested path.
2026-10-26	`1a692a7`, `6b95cf5`	CI (`testy.yml`) with all GitHub Actions **pinned to commit SHAs** (organisation requirement); thresholds and paths in a settings file, never in code; local overrides may only change existing keys.
2026-10-26	`8164ae3`, `feb8eff`	**Synthetic data generator** (`qc.syntetyka`): procedural crowns and bridges, simulated scans with noise 0.02-0.04 mm and chips 0.2-0.6 mm, so the whole pipeline can be developed and tested **without a single patient file**. `tests/dane/README.md` documents that every file there is generated, with size limits enforced by a test (`<= 300 KB` per file, `<= 1 MB` total).
2026-10-26/27	`ba2c49d`, `7df3dcf`	Defect inspection (`qc.inspect`): deviation maps between scan and design, chip detection, robustness to scanner jitter and smoothing after review.
2026-10-27	`2a3434b`, `be9c000`, `57644c3`	STL catalogue (`qc.catalog`): indexes order folders into a **local SQLite** database; parser extracts tray number and surname from folder names (documented with fictional names only); unique path per source, corrupted or locked STL recorded as error without stopping the scan; missing OneDrive source skipped without marking deletions; files older than a retention window are not re-indexed.
2026-10-27	`84f4e8f`, `321e069`, `d1b2003`	Identification (`qc.match`): geometric pre-filter, RANSAC/ICP registration, ranking with confidence classes ("certain" / "ambiguous"); thresholds moved to settings; morning mode.
2026-10-27	`e8e6cb8`, `a73fa31`	Plate handling (`qc.plate`): alignment, plate number reading, cutting into per-slot fragments; robustness fixes.
2026-10-27	`8dc6867`	Crash fix: multithreaded OpenBLAS called from Python threads concurrently with Open3D (OpenMP) caused an access violation; package import now forces a single BLAS thread, with ctypes fallback when numpy is already loaded; regression test `test_watki.py`.
2026-10-28	`e1eb9ef`, `d0728c4`, `7bb65a7`	**Acceptance metrics** (`qc.metryki`): one command runs the full chain on synthetic plates and reports detected / missed / false results against ground truth; "honest denominators" (phantoms in empty slots count as misses, "no loophole in the scoring" - `7bb65a7`), deterministic per seed, separate CI workflow `metryki.yml`.
planned (`qc/excel/OPIS.md`, `qc/scanner/OPIS.md`, `qc/session/OPIS.md`)	-	Excel integration limited to **writing one cell colour** in column B, every write appended to a CSV audit log, development only on a copy of the workbook; scanner-folder watcher accepts a file only after it is completely written; session results stored in local SQLite so every decision is reproducible. The milling-report parser is explicitly on hold **until an anonymised sample report exists**.

Why it belongs in this appeal: it is an active project where I am the person responsible for how patient-identifying data flows through software on a company workstation. The design decisions above (data minimisation towards the LED

hardware, no egress, local-only storage, synthetic test data, audit log for the one write into a business system, pinned CI) are the practical side of the "threat modeling" and "secure code review" work the CVP letter lists.

---

3. How this maps to CVP eligibility

The rejection letter asks for "CVE credit, bug bounty records, or published disclosures". I do not have those: the software is proprietary, deployed inside one manufacturing company, and the vulnerabilities I find are in my own code and in how it interacts with Windows, VNC servers and the factory network. What the history above shows instead is:

1. **Sustained defensive security engineering** (2026-09-10 to 2026-10-26): reviews with numbered findings, red tests before fixes, fix PRs, regression tests, documented residual risk.
2. **Real vulnerability classes found and fixed in my own product**: privilege escalation via an elevated scheduled task with a user-writable directory (R-02/R-04/R-05), secret leakage into a plaintext UI field (`f7c1fe9`), private-key leakage into a diagnostics ZIP (`1e38fdd`), weak RSA parameters accepted from a network peer (`b8db46e`), CSV formula injection, replay in a UDP state protocol, named-pipe ACL mismatch across the UAC boundary.
3. **Protocol-level work**: an own RFB/VNC client including RSA-AES authentication against real industrial devices, with negative tests.
4. **Supply-chain and CI controls**: pinned scanners and actions, secret scanning and SAST that a PR cannot disable, Authenticode signing, checksum-verified updates over HTTPS only.
5. **Scanner engineering (2.6a)**: an own secret/PII scanner with honest exit codes (incomplete scan is never "clean"), run from a trusted host copy rather than the PR checkout, extended to release artifacts and archives; outbound secret filtering of alerts; weekly Trivy CVE scanning of production images with the findings actually acted on.
6. **Patient data by design (2.9)**: a medical-adjacent workstation program (dental prosthetics QC) built from the first commit with data minimisation, no network egress, synthetic-only test data, local storage and an audit log for its single write into a business system.

This is the kind of work the letter describes as in scope for the program's audience ("secure code review, threat modeling, patching known issues, finding vulnerabilities in your own source code"). I am asking for the application to be re-evaluated on this evidence.

---

4. What I am asking for

---

5. Verification

- All SHAs resolve in `mbuasm/Maszyny-alert` (961 commits on `main`), `mbuasm/VNC-Alert` (19 commits on `main`), for section 2.6a `mbuasm/serwer-laptop` (1182 commits on `main`), or for section 2.9 `mbuasm/qc` (64 commits on `main`). Repositories are private; read access can be granted to a reviewer account on request, or I can provide `git log --stat` exports for the listed commits.
- Commit messages are in Polish; the summaries above are faithful translations.
- Some commits carry `Co-Authored-By: Claude ...` trailers: the work was done with Claude Code under my review, which is also why I am applying to the program.